

Information Security Policy

System: wealth-navigator **Owner:** Matt Fellows — matt@tangiblevalue.com **Version:** 1.0 **Effective date:** 2026-05-06 **Review cadence:** annually, or on material change.

1. Purpose & Scope

This policy describes how wealth-navigator protects the confidentiality, integrity, and availability of the data it handles.

In scope: - The wealth-navigator web application (React frontend, Express backend, Firestore database). - All third-party integrations that touch user financial data — currently **Plaid** and **Firestore**. - The infrastructure the app runs on — currently **Vercel** (serverless functions + static hosting). - The development workflow, including the GitHub repository and developer endpoint devices.

Out of scope: - Anything outside the wealth-navigator codebase or its directly-attached infrastructure.

Operating model: wealth-navigator is operated by a single individual (the Owner) and is intended for personal use only. There are no employees, contractors, or third-party operators. Any reference to “personnel” in this policy refers to the Owner alone.

Registration is restricted to the Owner via an allow-list mechanism enforced in code (backend/routes/auth.js → `isAllowedToRegister`). The allow-list is configured through the `REGISTRATION_ALLOWLIST` environment variable. In production: - An empty allow-list **disables registration entirely** (fail-closed). - The `/api/auth/demo` endpoint is disabled unless `ALLOW_DEMO_LOGIN=true` is explicitly set.

Authentication: the application enforces email + password + WebAuthn passkey. Once the Owner registers a passkey (via `/security` in the app), every subsequent login requires both factors before a JWT is issued. The passkey ceremony is implemented in `backend/services/passkeyService.js` (@simplewebauthn/server) with the RP ID/origin set per environment via `WEBAUTHN_RP_ID` and `WEBAUTHN_ORIGIN`. JWTs are 7-day, HS256-signed (`JWT_SECRET`), and stored client-side in `localStorage`.

Authorization: in production, every data route uses the `optionalAuth` middleware which **fails closed** when no valid token is present (HTTP 401). The legacy “silent demo fallback” is disabled in production. Demo behavior is preserved only in development.

Any change to the allow-list, registration controls, or authentication flow constitutes a change in the Operating Model and requires this policy to be re-reviewed.

2. Roles & Responsibilities

Role	Person	Responsibility
Security Owner	Matt Fellows (matt@tangiblevalue.com)	All decisions and obligations described in this policy. Single point of contact for Plaid security inquiries.
Incident Responder	Same	Triage and response for any incident affecting user data.

If/when this app moves out of solo operation, this section must be re-scoped before the change.

3. Asset Inventory

Asset	Sensitivity	Where stored	Encryption at rest
User account records (email, password_hash)	High (PII + credential material)	Firestore users	Firestore-managed (AES-256, Google-managed keys)
Plaid access_token	Critical — direct path to bank data	Firestore plaid_items.access_token	App-layer AES-256-CBC plus Firestore-managed
Plaid item_id	Medium	Firestore plaid_items.item_id	Firestore-managed
Plaid synced data (transactions, holdings, liabilities, balances)	High	Firestore (plaid_transactions, plaid_holdings, plaid_liabilities, balance_snapshots)	Firestore-managed
App secrets (JWT_SECRET, ENCRYPTION_KEY, PLAID_SECRET, FIREBASE_SERVICE_ACCOUNT, CRON_SECRET)	Critical	Vercel encrypted environment variables; local .env (developer machine)	Vercel-managed; FileVault on developer machine
Source code	Public	GitHub mmfellows/wealth-navigator	n/a (public)

4. Control Domains

This policy is implemented through the following sub-policies (each in this folder):

- **Access Control** — ACCESS_CONTROL.md
- **Encryption** — ENCRYPTION.md
- **Vulnerability Management** — VULN_MGMT.md
- **Privacy** — PRIVACY_POLICY.md
- **Consent** — CONSENT.md
- **Data Retention & Deletion** — DATA_RETENTION.md

5. Incident Response (one-page)

If a security event is suspected (credential leak, unauthorized access, suspicious sync activity, dependency CVE actively being exploited, etc.):

1. **Contain** within 1 hour: rotate any potentially-exposed secret (JWT_SECRET, ENCRYPTION_KEY, PLAID_SECRET, FIREBASE_SERVICE_ACCOUNT, CRON_SECRET); take the app offline via Vercel if data exfiltration is plausible.
2. **Assess** within 24 hours: determine what data was or could have been accessed. Review Vercel logs, Firestore audit logs, and sync_logs.
3. **Notify** within 72 hours of confirmation: contact Plaid (security@plaid.com) if Plaid-derived data is implicated. Notify any affected users by email.
4. **Remediate**: patch the root cause; document in this policy.
5. **Post-mortem**: append a brief incident note to INCIDENTS.md (create as needed) — date, what happened, what changed.

6. Change Management

- All code changes go through the GitHub repository (main branch).

- Significant security-relevant changes (auth, encryption, Plaid integration, secrets management) require an explicit note in the commit message and an update to the affected policy file in the same commit.

7. Review

This policy and its sub-policies are reviewed annually (calendar reminder set) and any time the architecture changes materially. Each review updates the **Effective date** and increments the **Version**.

This document is the source of truth for security decisions in wealth-navigator. If practice diverges from policy, update the policy.